Testing IoT Security: The Case Study of an IP Camera

Peshraw Ahmed Abdalla
Department of Computer Science
University of Halabja
Halabja, Iraq
peshraw.abdalla1991@gmail.com

Cihan Varol
Department of Computer Science
SHSU
Texas, USA
cvarol@shsu.edu

***Abstract*— While the Internet of Things (IoT) applications and devices expanded rapidly, security and privacy of the IoT devices emerged as a major problem. Current studies reveal that there are significant weaknesses detected in several types of IoT devices moreover in several situations there are no security mechanisms to protect these devices. The IoT devices' users utilize the internet for the purpose of control and connect their machines. IoT application utilization has risen exponentially over time and our sensitive data is captured by IoT devices continuously, unknowingly or knowingly. The motivation behind this paper was the vulnerabilities that exist at the IP cameras. In this study, we undertake a more extensive investigation of IP cameras' vulnerabilities and demonstrate their effect on users' security and privacy through the use of the Kali Linux penetration testing platform and its tools. For this purpose, the paper performs a hands-on test on an IP camera with the name ("Intelligent Onvif YY HD") to analyzes the security elements of this device. The results of this paper show that IP cameras have several security lacks and weaknesses which these flaws have multiple security impacts on users.**

Keywords—Internet of Things, Security, Vulnerability, IP Camera, Penetration Testing.

I. INTRODUCTION

The Internet of Things or IoT appeared when billions of intelligent devices are joined together, is considered to be the new generation of internet and will come to be a charming aim for attackers to abuse in the cyber world [1].

Any physical component within the IoT may interact with or without human interference [2]. Now, a new form of IoT applications has been developed with different infrastructures such as surveillance systems, healthcare, smart environment, and manufacturing and so on. However, IoT technologies are in their child's steps as well as several IoT-related technological challenges need to be defeated. One of the most serious barriers to IoT is security [3].

The devices that are used to monitoring such as IP cameras are forms of digital video cameras primarily fixed in different environments to the aim of surveillance, which can also broadcast its information over the internet, with remote access functionality, the live video stream can be accessed from various machines at the same time, such as PCs, smartphones, tablets, and laptops or other portable devices.

Examples of security problems that might expose IP cameras could be:

- default login credentials.
- simple-to-imagine keys.
- poor authentication policy for password selection.
- low-method encryption of confidential information and data or sending data unaccompanied by encryption process and so on [4].

In this paper, we carry out a direct inspection upon an IP camera with the brand name (Intelligent Onvif YY HD) to investigate and reveal its security and privacy issues. Also, to complete this task and implement a hands-on test, the following steps are required:

- Data collection for system detection, network traffic analysis, and identification of services and ports.
- Traffic analysis.
- Check flaws in the mobile and Windows applications that support the IP camera.

The services that are hosted on clouds could be accessible from anywhere and at any time by its users [5]. The IP cameras enter the clouds as a backend while it starts, they are holding the connection active while the camera is online and turned on. This link enables the device to be properly connected and controlled at any time and from anywhere in the world through smart devices.

These IP cameras have a "P2P Cloud" feature, which is enabled by default. The camera enters and retains the link-up to a cloud infrastructure node. All licensed OS and mobile apps will access the device to get a live stream of the video over the cloud [6]. In normal situations, the users will connect to their devices indirectly via using the cloud. Consumers need not think about storage or connectivity problems as these are managed by the cloud on behalf of the clients [7]. The components of an IP camera shown in Fig. 1.

978-1-7281-6939-2/20/$31.00 ©2020 IEEE

Authorized licensed use limited to: University of Exeter. Downloaded on June 20,2020 at 19:06:16 UTC from IEEE Xplore. Restrictions apply.

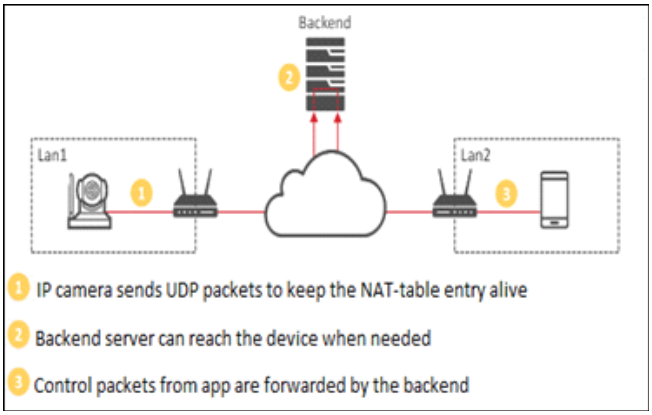


Fig. 1. Elements of an IP camera

II. Literature Review

In this section, the related work on security and privacy of IoT is shortly mentioned. The whole number of IoT devices is growing very quickly according to previous researches [8], [9]. The total number of internet-connected objects surpassed the world's population in 2008, also it is predicted to reach 50 billion by 2020 [8]. It is reported that 108 million network security cameras dispatched internationally in 2019 according to a research report by the IHS Markit [9].

Many authors, Seralathan et al. [10]. Basically analyzed the security of an internet-connected wireless smart camera and accessible to its internet-users (the writers do not identify the camera brand used for this research paper).

They also addressed concerns about how and why new malware targets IoT data directly. Their paper used Nmap and Wireshark, as two methods for collecting data and evaluating protection modules. Nmap was required to locate the internet protocol address of the camera and Wireshark was for analyzing network-level packets. Finally, it described the benefit of preserving IoT through several ideas on how to improve the protection of IoT systems and offering basic safety measures to decrease exploitation chances.

Two researchers, Alharbi and Aspinall [11] carried out an experiment on five IP cameras. They highlighted the categories of vulnerabilities that exist in their devices that used to surveillance and clarified the effect of these things on users' privacy and security.

In addition, this study reports several vulnerabilities in all of these cameras involving poor encryption policy, default passwords, no mechanism to lockout the IP camera account after several attempts to enter to the system with the wrong password by attackers (such as brute-force attack), unsecure video stream, bad key management encrypted video stream, user-sensitive leakage of details, unencrypted removable memory which stores videos and weaknesses in android apps that used to monitor devices.

Liranzo and Hayajneh [12] highlighted the current privacy problems by having a smart camera with the brand name (D-Link DCS-930L). In their study, they addressed the various security risks and ways in which either someone utilizing the same local area network or from outside the home network zone may breach the device. This paper also recommended many strategies for reducing current challenges and protecting users ' privacy and security.

III. Potential Attacks of IP Cameras

The IoT devices and IP cameras are possible for several types of attacks by attackers this section explains some type of these attacks.

- Eavesdroppers: When a hacker is monitoring data that pass through the network level to the aim of achieving that information in the form of plaintext [13].
- The Man in the Middle (MITM): If a hacker attempts inappropriate implementation of Secure Sockets Layer (SSL) to redirect all correspondence into his/her stations to observe the network traffics that transmit in form readable text [14].
- The man at the end (MATE): If the attackers are inspecting or tamping the software or hardware of the physical device.
- The malicious code may be programmed to target a network part that will compromise the entire system.
- The Wi-Fi Sniffers: Whenever an abuser attempts to find a router key and sign in as a trustworthy member of the system and network in order to control all the devices that work on that network [11], [15].
- The app developers: User activity may be detected by injecting trackers into the smartphone apps or by installing malicious software, or information that leaks [11].
- Third parties: Server sides such as Amazon video streaming platforms and servers for data analysis both have an impact on the privacy of users [11].

Also, after hacking or unauthorized access to the IoT devices it is possible to be used in some different types of attacks such as in distributed denial of service attack (DDoS), an example of this situation is the “Mirai botnet” [16].

IV. Methodology for Penetration Testing

This section defines the meaning of penetration testing and explains the methodology and tools of pen-testing.

A. Penetration Testing

This process is also known as “pen test” or “ethical hack”. This includes a compilation of procedures and processes to evaluate the security of the devices in a system and organizations [17].

Simultaneously, in this article, the primary objective of penetration testing is to identify flaws in a particular IoT device (an IP camera) and the protection of an enterprise, as well as to diagnose the danger, vulnerability and then how systems and things breakdown.

Authorized licensed use limited to: University of Exeter. Downloaded on June 20,2020 at 19:06:16 UTC from IEEE Xplore. Restrictions apply.

B. Methodology for Pen Testing

To achieve reliable testing of weaknesses in the systems and mechanisms, the method for performing a pen-test in a system has to be determined. The process consists of three main stages as explained below:

1) Defining the Area

It is essential to define the experiment scope in the first phase of the process of testing. The testing requirements will cover the whole structure of the system and machines, or they could clearly aim the IoT things that operate on that network.

2) Implementation of the Process

It is the second step of the process of pen testing which implements by the pen testers, which involves obtaining all the valuable data and information about the devices that work on the system to expose security flaws and gaps that may put the entire system to risk. The pen testers have to ensure that services, networks or equipment are not vulnerable to a protection breach, through checking and reviewing the machine, which may require unauthorized entry to the network of the system.

3) Outcomes reporting and presentation

Once the vulnerability scanning was completed, the tester must evaluate all the gathered information from the inspection process. The report on the presentation will include the following parts:

- Documentation of every device's vulnerabilities.
- Classification of threats in the system into high, medium, and low.
- Presentation of vulnerability, threats, and weaknesses discovered on the system's device.
- Information on the weaknesses and strengths of security features in the system.

Eventually, the testers will offer some suggestions to patch identified protection vulnerabilities as well as provide comprehensive information about overcoming the system's limitations [18], [19].

C. Pen Testing Tools

There are some tools and software are used successfully in the experiment part of this paper to reveal the vulnerability types in the IP camera, the tools are mentioned below.

- Kali Linux: as a well-known platform for examining security threats and vulnerable finders.
- Wireshark: for analyzing network-level packets.
- Nmap: as a network discovery tool, it is also known as network mapper.
- Arpspoof and Mitmproxy: to the aim of implement MITM attacks.
- Netdiscover: to collect detail information about the network's devices.
- Bettercap: it used for sniffing and spoofing.

V. Case Study of an IP Camera

This part will include the investigation of the current security characteristics in an IP camera and attempt to discover the flaw in the security of the device. The brand name of the IP camera that used in this paper is ("Onvif YY HD"). The picture of the device is shown in Fig. 2.

Fig. 2. The IP camera

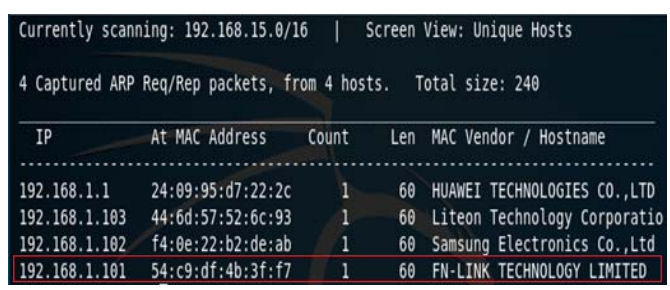
This IP camera has some features such as it supports two-way audio and allows us to interact with its customers what they see. Also, it supports the function of the pan, tilt, and zoom (PTZ control) and with the wireless feature, it can be moved to another location easily inside the LAN network. The below table explains detail information about the device.

TABLE I. Detail Information About the Device

Name of the camera	Onvif YY HD
ID of camera	8861084
Default user name of the camera	None
Default password of the camera	123
Pan, tilt, and zoom feature	Yes
Camera MAC address	54:C9:DF:4B:3F:F7
LAN IP (router)	192.168.1.101
Windows application	CMS Client
Android app	YOOSSE and YYP2P

A. Collecting of Information

This section concerns on gathering of multiple kinds of data through using Kali Linux and its tools, such as Nmap and Netdiscover. In this step we have to determine the number and types of devices that work on the system, this task can be done by calling the Netdiscover tool in the Kali Linux command line, after that, all machines running on the network will be shown, as demonstrated in Fig. 3.



```
Currently scanning: 192.168.15.0/16   |   Screen View: Unique Hosts

4 Captured ARP Req/Rep packets, from 4 hosts.   Total size: 240
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
-----------------------------------------------------------------------------
192.168.1.1     24:09:95:d7:22:2c      1      60  HUAWEI TECHNOLOGIES CO.,LTD
192.168.1.103   44:6d:57:52:6c:93      1      60  Liteon Technology Corporatio
192.168.1.102   f4:0e:22:b2:de:ab      1      60  Samsung Electronics Co.,Ltd
192.168.1.101   54:c9:df:4b:3f:f7      1      60  FN-LINK TECHNOLOGY LIMITED
```

Fig. 3. The result of Netdiscover scan

Authorized licensed use limited to: University of Exeter. Downloaded on June 20,2020 at 19:06:16 UTC from IEEE Xplore. Restrictions apply.

To test the opened port(s) in the device, by Nmap search all of the ports can be check whether it is close or open from range 1 to 65535. This task can be achieved by writing this command "[nmap -p1-65535 IP]" in the Kali terminal, it will check the ports at that limited range, the command results can be seen in the Fig. 4.

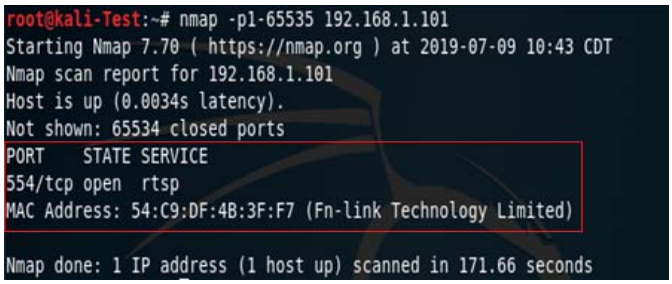


Fig. 4. Checking the ports of the camera

As can be seen from the above figure the state of transmission control protocol TCP port 554 is open hosting on a service of real-time streaming protocol RTSP.

Moreover, one further Nmap test with the option "[nmap -O IP]" is needed to find more detail about the camera and its operating framework. The outcome of this command is shown in Fig. 5 as the operating system type is "Linux 2.6.32".

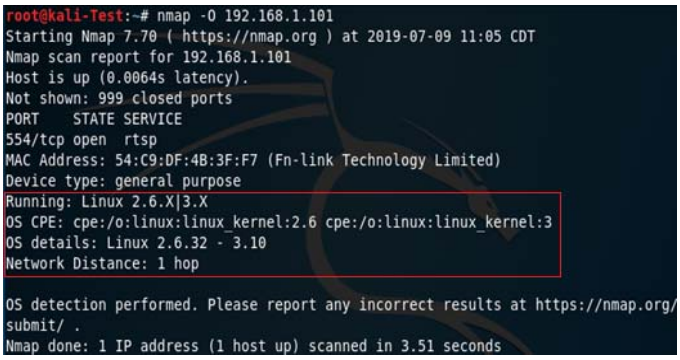


Fig. 5. Nmap search to determine the type of camera OS

B. *Default Credential of the Camera*

Peer-to-peer "P2P" Cloud feature operates with both the P2P ID and the password of the camera. This device seems more vulnerable in this case since on the back of the device two default information was written for both device identification and password as can be seen in Fig. 6. There is a page to "Add online device" in the YYP2P android app that allows users to receive the live video from the device by writing (default ID=886244 and default P2P password = 123).

Excepting for when the consumer changes the default P2P password to a stronger one, someone can sign in and connect with the system by "investigating" different identifications of the cloud because the P2P ID and password are still the only authentication data to access this IP camera.

On the other hand, the YYP2P android application's policy for setting a password to the P2P is surprisingly weak because it has no policy, while the user wants modifies the default one. When the customer wants to modify the default password to another one with just one letter or character the app will approve it. This vulnerability detected in the smartphone app will put the device into an unsafe state since, in this situation, it is possible to make the devices a botnet by attackers. Default credentials and add the online device page in the YYP2P app shown in Fig. 6.

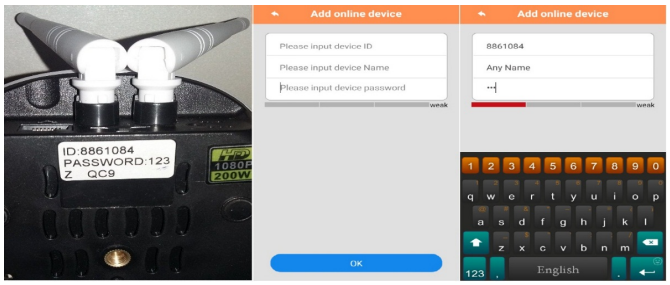


Fig. 6. Default credential of the device

C. *Network Traffic Inspection*

Through using Kali network packet capture software like Mitmproxy and Wireshark, all network-level packet details can be detected and tracked. Both the IP camera and the smartphone are attached to the internet via the same local area network so that Wireshark and Mitmproxy can record and monitor all transmitted packets. A simulated man in the (MITM) attack, carried out through the Arpspoof tool at the Kali in order to inspect the network traffic.

Throughout the data transmission process, all transmitted data can be seen that transmitted as plaintext. It means that all sensitive data exchanged between the android app and IP camera, the IP camera server and app, the IP camera and its server transmitted in readable text. Authentication details sent from the android app to the server in plaintext, which can be used by attackers to risk all devices and IP cameras assigned to the account.

The transfer of critical data and confidential information in the plaintext will not only jeopardize the IP camera's security as well as put the security of the LAN to an insecure situation. The Yoosee android app pushes Wi-Fi's service set identifier SSID and password of that SSID in the initial stages of registration of the IP camera. That private information was sent in plaintext. If an MITM attack performed by an attacker, at that time he/she can observe the traffic, also it is possible to enter the network and inside it sniff all further personal data. The Wi-Fi credentials which sent in plaintext shown in Fig. 7.

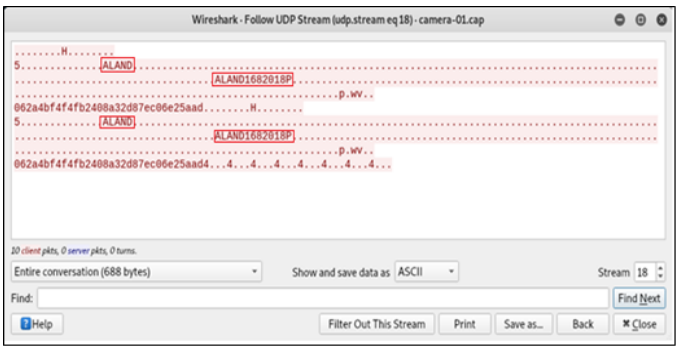


Fig. 7. Default credential of the device

Authorized licensed use limited to: University of Exeter. Downloaded on June 20,2020 at 19:06:16 UTC from IEEE Xplore. Restrictions apply.

With Mitmproxy documented packets held credential data in readable text. It includes customer information including account information (username in plaintext and password decode with MD5 also it can be returned to its original form by hash decryption tools). As demonstrated in Fig. 8.

```
Flow Details
2019-10-25 15:38:25 POST http://api4.cloud-links.net/Users/LoginCheck.ashx
                    ← 200 text/plain 297b 1.64s
        Request                Response                Detail
Content-Length:  109
Content-Type:    application/x-www-form-urlencoded
Host:            api4.cloud-links.net
Connection:      Keep-Alive
User-Agent:      Apache-HttpClient/UNAVAILABLE (java 1.4)
URLEncoded form                                          [m:auto]
User:        Peshraw.abdalla1991@gmail.com
Pwd:         5416D7CD6EF195A0F7622A9C56B55E84
VersionFlag: 1
AppOS:       3
AppVersion:  10
```

Fig. 8. Account credentials

D. Inspection of Application Login Credentials

The Login details are stored in plaintext form when checking the account of this device within the android apps. As can be seen from Fig. 9, authentication elements for the YYP2P app are highlighted with yellow color. The account authentication elements for both licensed applications that use by a smartphone to monitor the IP camera using an android operating system are vulnerable at this point. The directory path is highlighted by a red rectangle.

```
root@a33g:/data/data/con.yyp2p/shared_prefs # ls
WebViewChromiumPrefs.xml
account_shared.xml
con.yyp2p_preferences.xml
gwell.xml
json.xml
umeng_general_config.xml
root@a33g:/data/data/con.yyp2p/shared_prefs # cat gwell.xml
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
    <boolean name="is_remember_pass_email" value="true" />
    <long name="0315730461last_auto_check_update_time" value="1562940710690" />
    <int name="recent_login_type" value="1" />
    <string name="recentPass_email">1q2w3e4r</string>
    <string name="recentName_email">Peshraw.abdalla1991@gmail.com</string>
</map>
root@a33g:/data/data/con.yyp2p/shared_prefs #
```

Fig. 9. Username and password at YYP2P android app

E. Real-Time Streaming Protocol

The outcome of the Nmap brute-force attack to find possible RTSP links, it discovers a URL to the RTSP which can be used to retrieve the live video from the device. This feature is working as a vulnerable service since it does not needs any authentication info. The discovered URL by Nmap is "rtsp://device_IP/onvif1".

VI. Conclusion

Current studies reveal that there are significant weaknesses detected in several types of IoT devices. In this paper, the security components of wireless IP cameras with the brand name ("Intelligent Onvif YY HD") explored through some techniques and methods of penetration testing.

The findings of this study showed that this device has different flaws and weaknesses, including default credentials; as well as the identifier default number of the device is weak, that it makes the device to find by abusers easily. There are several different types of sensitive information transferred without utilizing encryption techniques. Lack of encryption is another point revealed by this study since in some cases the sensitive data is protected by weak methods. Also, the android applications have weaknesses in the cases of storing sensitive data in plaintext and lack of protection mechanisms and RTSP works as a vulnerable service.

Finally, to provide stronger security features these points must be accounted for by the device manufacturers.

References

[1] R. Roman, P. Najera, and J. Lopez, "Securing the internet of things," Computer, pp. 51-58, 2011.

[2] Z. Bi, L. Da Xu, and C. Wang, "Internet of things for enterprise systems of modern manufacturing," IEEE Transactions on industrial informatics, vol. 10, pp. 1537-1546, 2014.

[3] S. Li and L. Da Xu, Securing the internet of things: Syngress, 2017.

[4] K. J. W. Bjørneset, "Testing Security for Internet of Things: A Survey on Vulnerabilities in IP Cameras," Master, Department of Information, University of Oslo, 2017.

[5] P. A. Abdalla and A. Varol, "Advantages to Disadvantages of Cloud Computing for Small-Sized Business," in 2019 7th International Symposium on Digital Forensics and Security (ISDFS), 2019, pp. 1-6.

[6] Balthasar and Fabian. (Nov 16, 2017, November 07). The Cloud exposes your private IP cameras. Available: https://srlabs.de/bites/cloud-cameras/

[7] A. Tekeoglu and A. S. Tosun, "Investigating security and privacy of a cloud-based wireless IP camera: NetCam," in 2015 24th International Conference on Computer Communication and Networks (ICCCN), 2015, pp. 1-6.

[8] M. Swan, "Sensor mania! the internet of things, wearable computing, objective metrics, and the quantified self 2.0," Journal of Sensor and Actuator networks, vol. 1, pp. 217-253, 2012.

[9] I. Markit, "The top trends of 2019: powered by transformative technologies," 2019.

[10] Y. Seralathan, T. T. Oh, S. Jadhav, J. Myers, J. P. Jeong, Y. H. Kim, et al., "IoT security vulnerability: A case study of a Web camera," in 2018 20th International Conference on Advanced Communication Technology (ICACT), 2018, pp. 172-177.

[11] R. Alharbi and D. Aspinall, "An IoT analysis framework: An investigation of IoT smart cameras' vulnerabilities," 2018.

[12] J. Liranzo and T. Hayajneh, "Security and privacy issues affecting cloud-based IP camera," in 2017 IEEE 8th Annual Ubiquitous Computing, Electronics and Mobile Communication Conference (UEMCON), 2017, pp. 458-465.

[13] A. Gilchrist, IoT Security Issues. Berlin: Walter de Gruyter, 2017.

[14] M. M. Hossain, M. Fotouhi, and R. Hasan, "Towards an analysis of security issues, challenges, and open problems in the internet of things," in 2015 IEEE World Congress on Services, 2015, pp. 21-28.

[15] S. Siby, R. R. Maiti, and N. Tippenhauer, "Iotscanner: Detecting and classifying privacy threats in IoT neighborhoods," arXiv preprint arXiv:1701.05007, 2017.

[16] C. Kolias, G. Kambourakis, A. Stavrou, and J. Voas, "DDoS in the IoT: Mirai and other botnets," Computer, vol. 50, pp. 80-84, 2017.

[17] R. Baloch, Ethical hacking and penetration testing guide. New York: CRC Press, 2015.

[18] K. Cardwell, Building Virtual Pentesting Labs for Advanced Penetration Testing. Birmingham: Packt Publishing Ltd, 2016.

[19] EC-Council, penetration Testing: Procedures and Methodologies vol. 2: Cengage Learning, 2011.

Authorized licensed use limited to: University of Exeter. Downloaded on June 20,2020 at 19:06:16 UTC from IEEE Xplore. Restrictions apply.